RAPPORT TECHNIQUE

Déploiement Automatisé d'un SOC Hybride & Réponse Active aux Incidents

Infrastructure as Code · SIEM/XDR · DevSecOps

Auteur : Saïd SANGRE

Date : Septembre 2026

Domaine : Cybersécurité défensive — SOC & Détection d'Intrusion

1. Résumé Exécutif

Dans un contexte où la surface d'attaque des infrastructures numériques s'élargit continuellement, la capacité à détecter, corréler et neutraliser un incident de sécurité en un temps réduit constitue un enjeu opérationnel majeur pour toute organisation. Le présent rapport documente la conception, le déploiement et la validation d'un Security Operations Center (SOC) hybride, entièrement automatisé, reposant sur une approche Infrastructure as Code (IaC) et sur une chaîne d'outillage DevSecOps.

L'objectif de ce projet est double. D'une part, il s'agit de démontrer la faisabilité d'un provisioning reproductible et versionné d'un environnement de supervision de sécurité, depuis la création des machines virtuelles jusqu'à l'enrôlement des agents de télémétrie, sans intervention manuelle répétitive. D'autre part, le projet vise à valider, dans des conditions réalistes, l'efficacité d'une chaîne de détection et de réponse automatisée face à des scénarios d'attaque conformes au référentiel MITRE ATT&CK, avec pour finalité la réduction du Mean Time To Respond (MTTR).

L'architecture retenue combine un poste d'accès sécurisé (bastion), une cible supervisée exposant un service web, un nœud offensif dédié aux tests d'intrusion, et une plateforme SIEM/XDR (Wazuh) assurant la collecte, la corrélation et la visualisation des événements de sécurité. Le déploiement complet de cette topologie repose sur Vagrant pour la couche de virtualisation et sur Ansible pour la configuration applicative, garantissant l'idempotence et la traçabilité de chaque étape.

Les résultats obtenus démontrent qu'une attaque de reconnaissance réseau suivie d'une tentative de force brute SSH est détectée, corrélée et automatiquement contenue par un mécanisme de réponse active (firewall-drop) en quelques secondes, sans intervention humaine, validant ainsi l'apport concret de l'automatisation sur la réduction du temps de réponse aux incidents.

2. Architecture Technique et Topologie Réseau

L'environnement de laboratoire repose sur un réseau privé isolé, structuré autour de quatre machines virtuelles interconnectées, chacune assumant un rôle fonctionnel distinct dans la chaîne de sécurité. L'adressage IP est statique afin de garantir la reproductibilité du déploiement et la cohérence des règles de pare-feu et des flux de télémétrie. Le tableau ci-dessous synthétise la topologie retenue.

Machine	Adresse IP	Système d'exploitation	Rôle fonctionnel
Gateway / Bastion	192.168.56.10	Ubuntu 22.04 LTS	Point d'accès sécurisé et passerelle distante via Apache Guacamole
Target-Linux	192.168.56.20	Ubuntu 22.04 LTS	Serveur Apache exposé, supervisé par l'Agent Wazuh (télémétrie et FIM)
Kali-GUI	192.168.56.30	Kali Linux Rolling	Nœud d'attaque dédié aux tests d'intrusion (Nmap, Hydra)

Machine	Adresse IP	Système d'exploitation	Rôle fonctionnel
Wazuh-Server	192.168.56.50	Ubuntu 22.04 LTS	Stack SIEM/XDR complète (Wazuh Manager, Indexer, Dashboard)

Les flux réseau sont organisés selon une logique de segmentation fonctionnelle : le Gateway/Bastion centralise les accès distants via Apache Guacamole, isolant ainsi les postes de travail administrateur du reste de l'infrastructure. La machine Target-Linux, seule surface exposée volontairement, héberge un serveur Apache dont l'intégralité des journaux et des événements systèmes est remontée vers le Wazuh-Server par l'intermédiaire de l'Agent Wazuh installé localement. Le nœud Kali-GUI, quant à lui, n'est connecté qu'au segment interne du laboratoire et sert exclusivement à la simulation d'attaques contrôlées à des fins de validation défensive.

Le Wazuh-Server centralise l'ensemble de la stack SIEM/XDR : le Manager assure la réception et la corrélation des événements, l'Indexer (basé sur une architecture de type recherche et indexation) stocke les données de sécurité de manière structurée, et le Dashboard offre une interface de visualisation et d'investigation aux analystes.

L'accès distant à l'ensemble des machines du laboratoire est centralisé via Apache Guacamole, accessible depuis un simple navigateur web, sans nécessiter de client SSH ou RDP dédié sur le poste administrateur. La console ci-dessous confirme la disponibilité opérationnelle des connexions vers les nœuds Kali-GUI et Target-Linux.

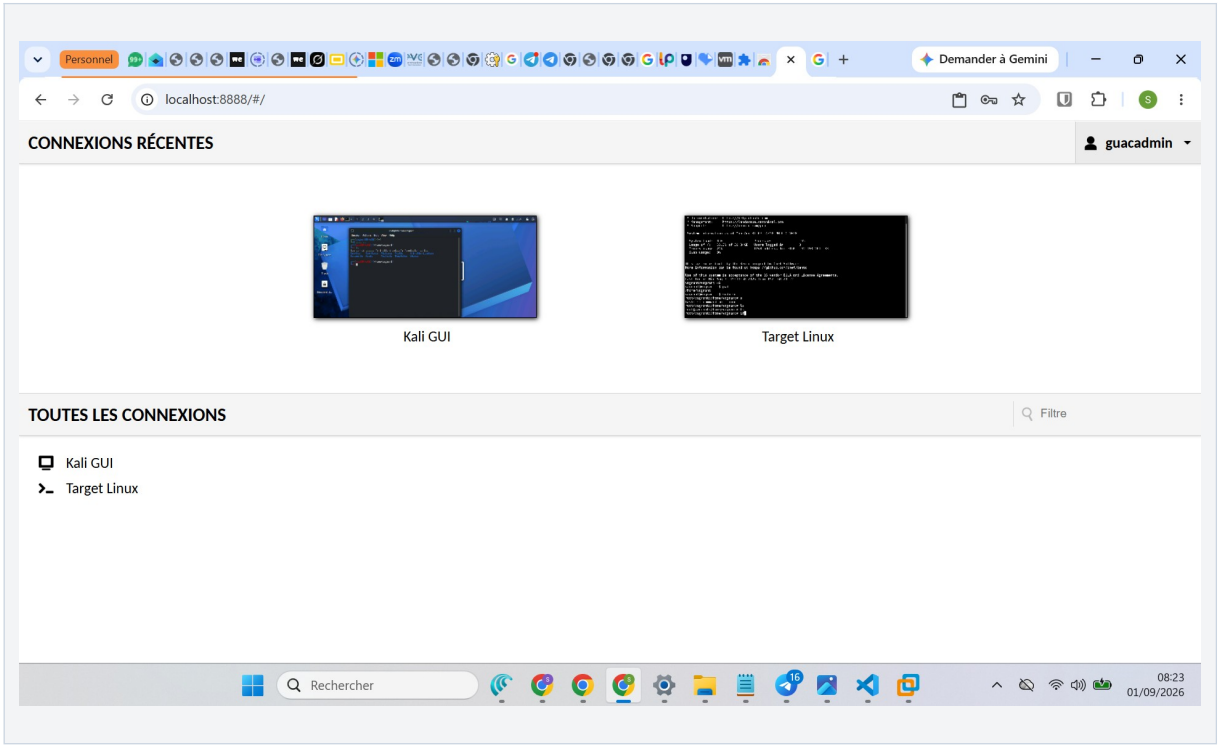


Figure 1 : Interface d'accès distant Apache Guacamole — connexions disponibles vers Kali-GUI et Target-Linux.

3. Déploiement et Provisioning Automatisé

La mise en place de l'ensemble du laboratoire repose sur une approche entièrement automatisée, en deux temps : la création et la configuration réseau des machines virtuelles via Vagrant, puis l'installation et le paramétrage des services applicatifs via Ansible. Cette double automatisation garantit un déploiement reproductible, versionnable dans un système de contrôle de version, et exempt de dérive de configuration (configuration drift).

3.1. Infrastructure as Code (IaC avec Vagrant/VMware)

Le fichier de description déclarative (Vagrantfile) définit l'ensemble des quatre machines virtuelles du laboratoire — leurs images de base, leurs ressources allouées (RAM, vCPU), leurs interfaces réseau privées et leurs adresses IP statiques respectives. L'utilisation du fournisseur VMware permet de bénéficier de performances adaptées à l'exécution simultanée d'une stack SIEM/XDR complète et d'un nœud d'attaque. Chaque exécution de la commande de provisioning recrée un environnement strictement identique, éliminant toute divergence entre les postes de développement, de test et de démonstration.

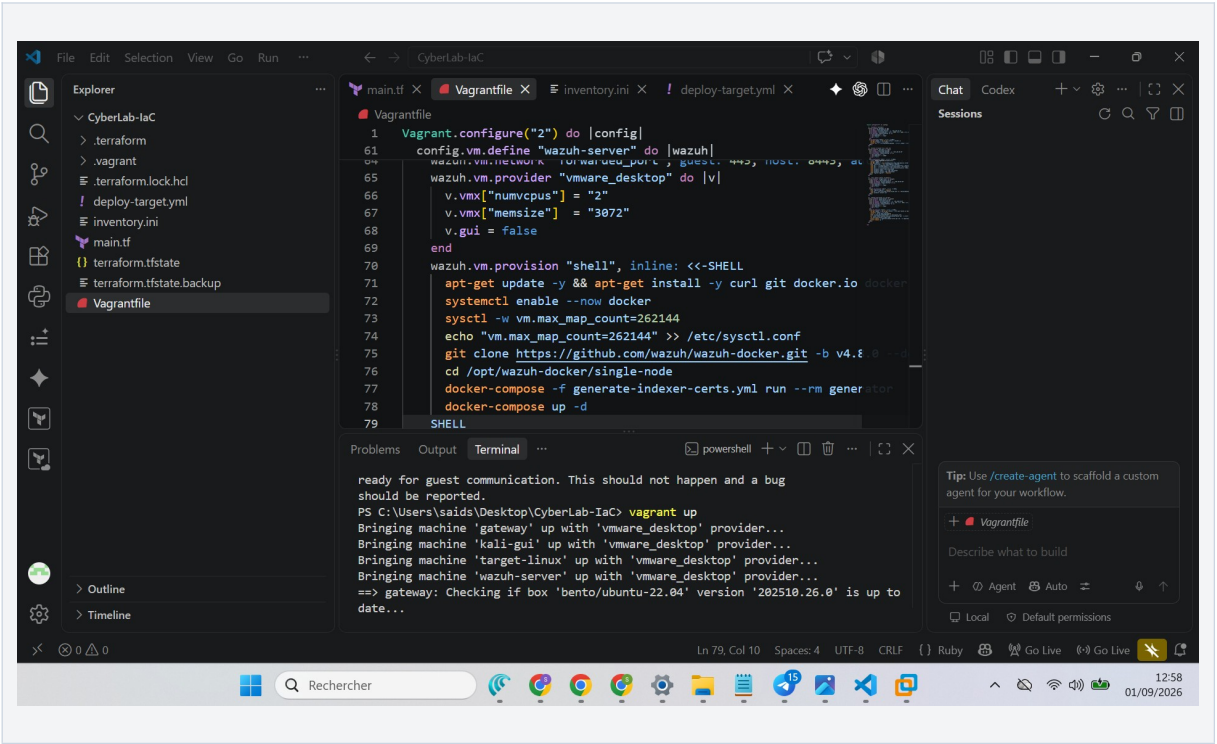


Figure 2 : Spécifications déclaratives du Vagrantfile (machines, ressources, adressage réseau statique).

3.2. Gestion de Configuration avec Ansible

Une fois les machines virtuelles provisionnées, la configuration logicielle est entièrement déléguée à Ansible. Des playbooks idempotents installent et paramètrent, selon le rôle de chaque hôte : le serveur Apache et l'Agent Wazuh sur Target-Linux, la stack Docker hébergeant Wazuh Manager/Indexer/Dashboard sur Wazuh-Server, ainsi que les outils offensifs (Nmap, Hydra) sur Kali-GUI. L'inventaire Ansible reflète directement la topologie réseau définie précédemment, assurant une correspondance stricte entre l'infrastructure décrite et l'infrastructure réellement déployée.

L'exécution du playbook se conclut par un récapitulatif (Play Recap) affichant un nombre de tâches en échec strictement nul (failed=0), condition indispensable à la validation du déploiement avant le

passage à la phase de supervision.

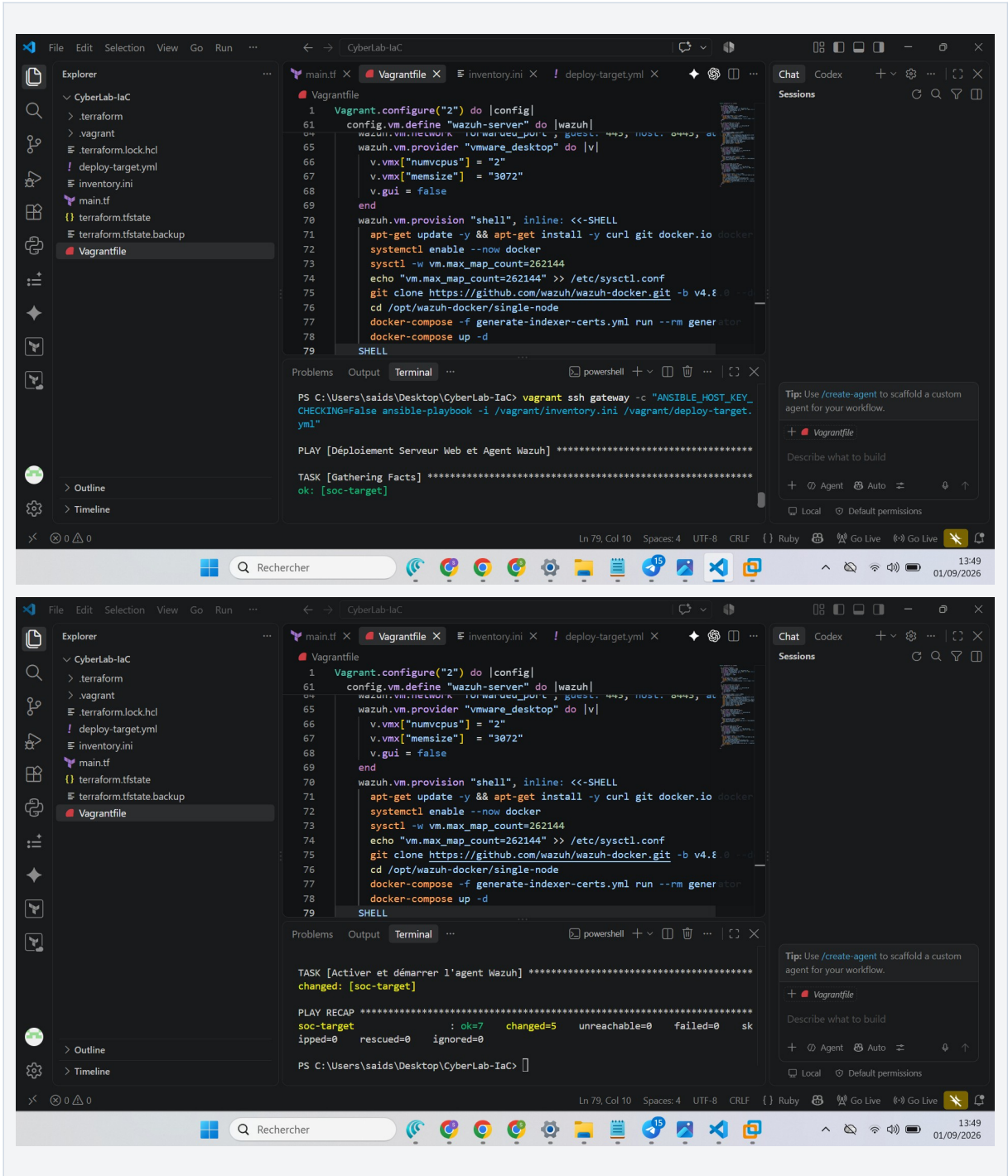


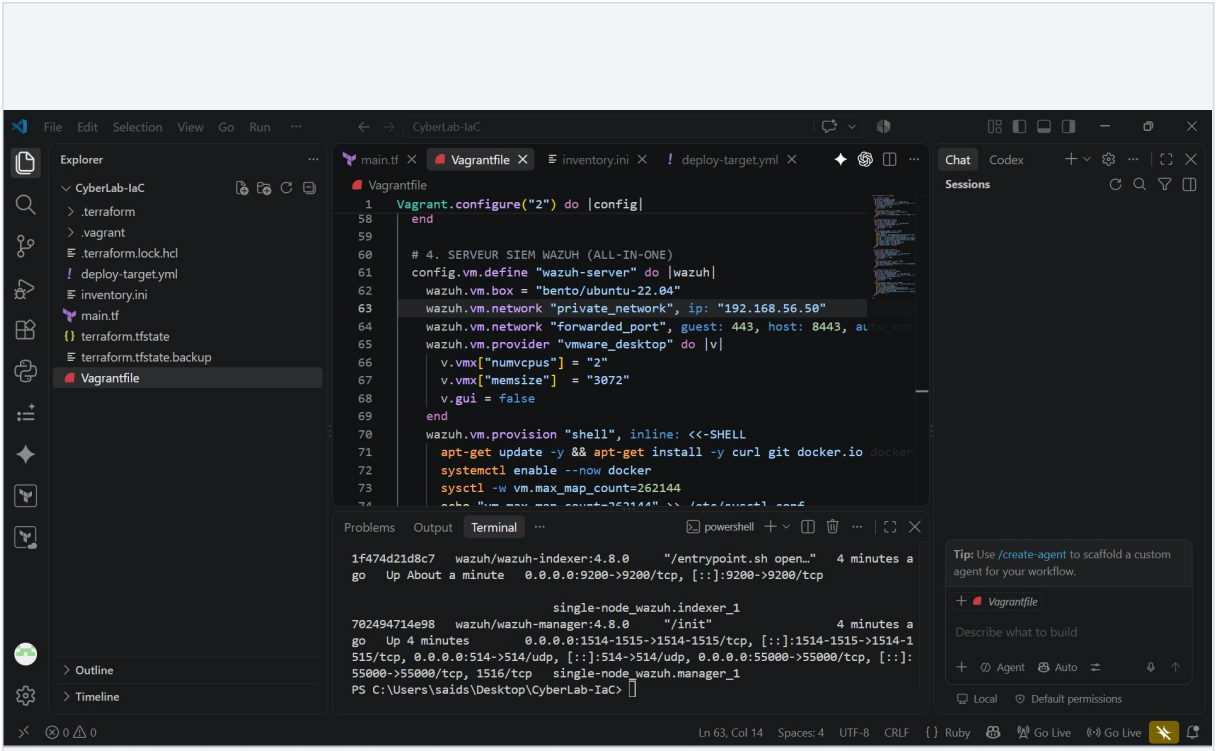
Figure 3 : Exécution du Playbook Ansible (déploiement de l'agent) et Play Recap confirmant failed=0.

4. Surveillance, Télémétrie et Enrôlement SIEM

Cette phase valide le bon fonctionnement de la plateforme de supervision une fois le provisioning achevé, en vérifiant successivement la disponibilité des microservices constituant la stack Wazuh, puis l'enrôlement effectif de l'agent déployé sur la machine cible.

4.1. Statut Opérationnel des Microservices Wazuh

La stack Wazuh est déployée sous forme de conteneurs Docker orchestrés, isolant chacun des trois composants majeurs (Manager, Indexer, Dashboard) au sein de son propre cycle de vie. La vérification de l'état des conteneurs (commande docker ps) permet de confirmer que l'ensemble des services est démarré, sain (healthy) et prêt à recevoir les flux de télémétrie en provenance des agents déployés sur le parc supervisé.



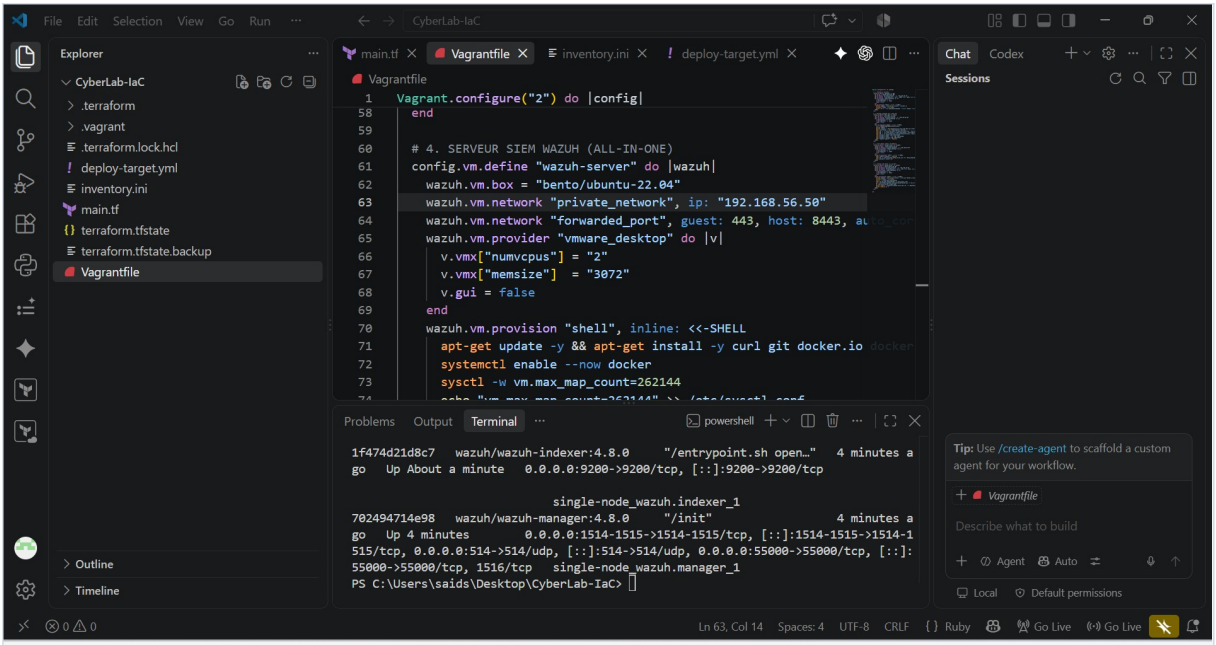


Figure 4 : Conteneurs Docker de la stack Wazuh en cours d'exécution (Manager, Indexer, Dashboard).

4.2. Authentification et Connectivité de l'Agent

L'Agent Wazuh installé sur Target-Linux est enregistré auprès du Manager au moyen d'une clé d'authentification unique, garantissant l'intégrité du canal de communication. La console de gestion permet de confirmer visuellement que l'agent transmet correctement sa télémétrie (journaux système, intégrité de fichiers, inventaire) et que son statut opérationnel est reporté comme Actif, condition préalable indispensable à toute détection ultérieure.

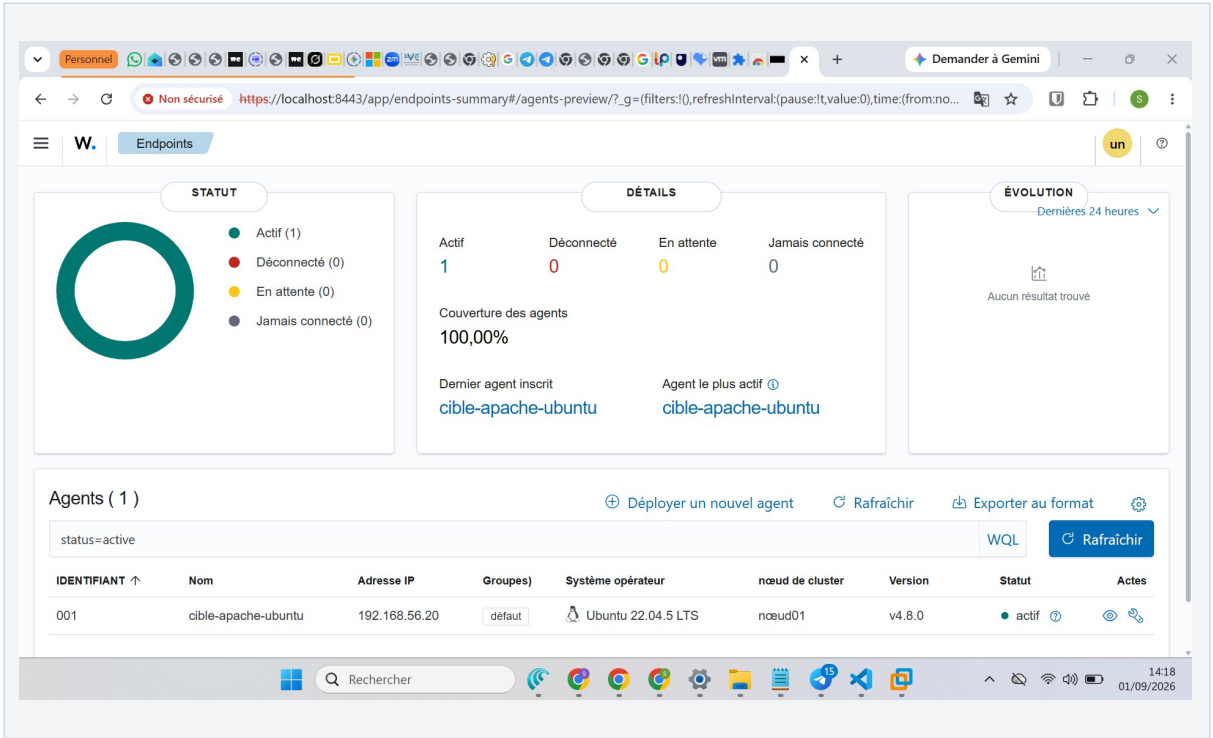


Figure 5 : Tableau de bord Wazuh confirmant le statut « Actif » de l'agent déployé sur Target-Linux.

5. Simulation d'Attaque et Détection MITRE ATT&CK

Afin de valider en conditions réelles la capacité de détection de la plateforme, une chaîne d'attaque en deux temps a été menée depuis le nœud Kali-GUI, reproduisant les étapes classiques de reconnaissance puis d'exploitation observées lors d'incidents réels. Chaque étape est cartographiée selon le référentiel MITRE ATT&CK afin de faciliter la lecture et la traçabilité des alertes générées.

5.1. Reconnaissance et Découverte Réseau

Un scan de ports est réalisé depuis Kali-GUI à l'aide de Nmap à l'encontre de la machine Target-Linux, dans le but d'identifier les services exposés. Ce scan révèle l'ouverture du port 22 (SSH) et du port 80 (service web Apache), confirmant la surface d'attaque de la machine cible et orientant la suite de la simulation vers une tentative d'authentification distante.

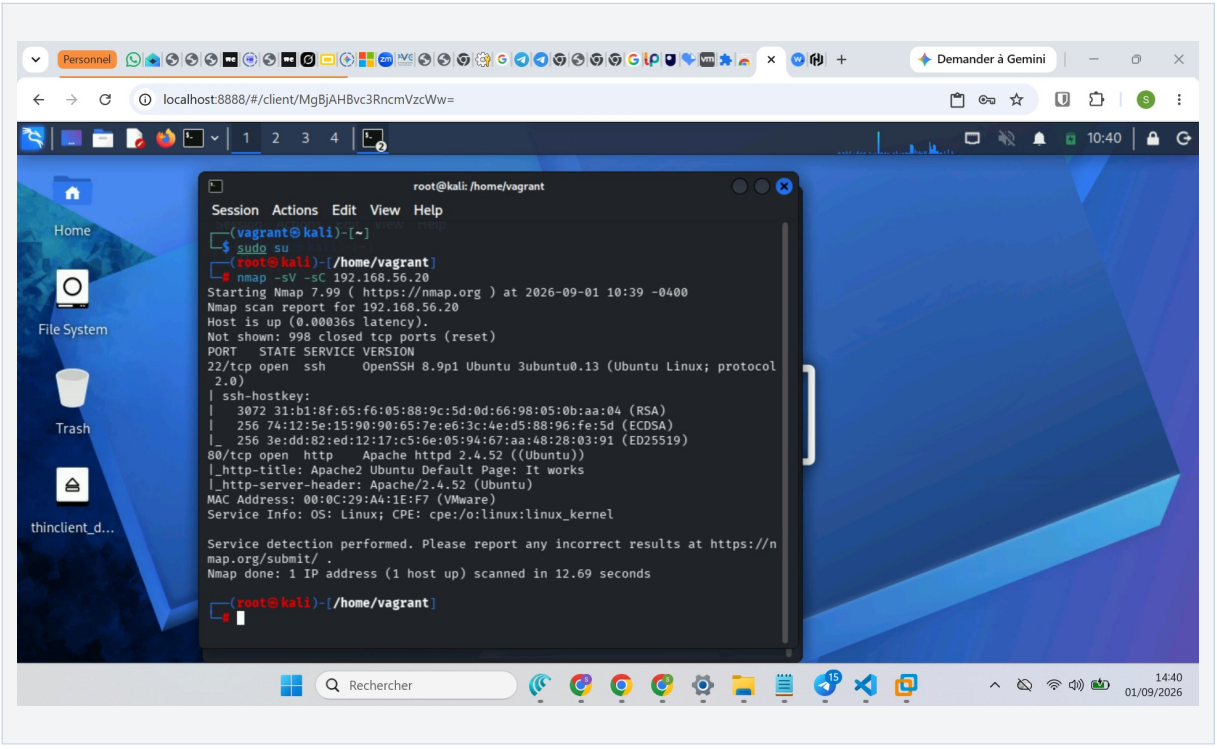


Figure 6 : Résultat du scan Nmap identifiant les ports ouverts 22 (SSH) et 80 (HTTP) sur Target-Linux.

5.2. Attaque par Force Brute SSH

Une attaque par force brute est ensuite menée sur le service SSH exposé, à l'aide de l'outil Hydra et d'un dictionnaire d'identifiants courants. Cette technique correspond à la tactique « Credential Access » du référentiel MITRE ATT&CK et vise à démontrer la capacité de la stack SIEM à détecter un volume anormal de tentatives d'authentification échouées en provenance d'une même source.

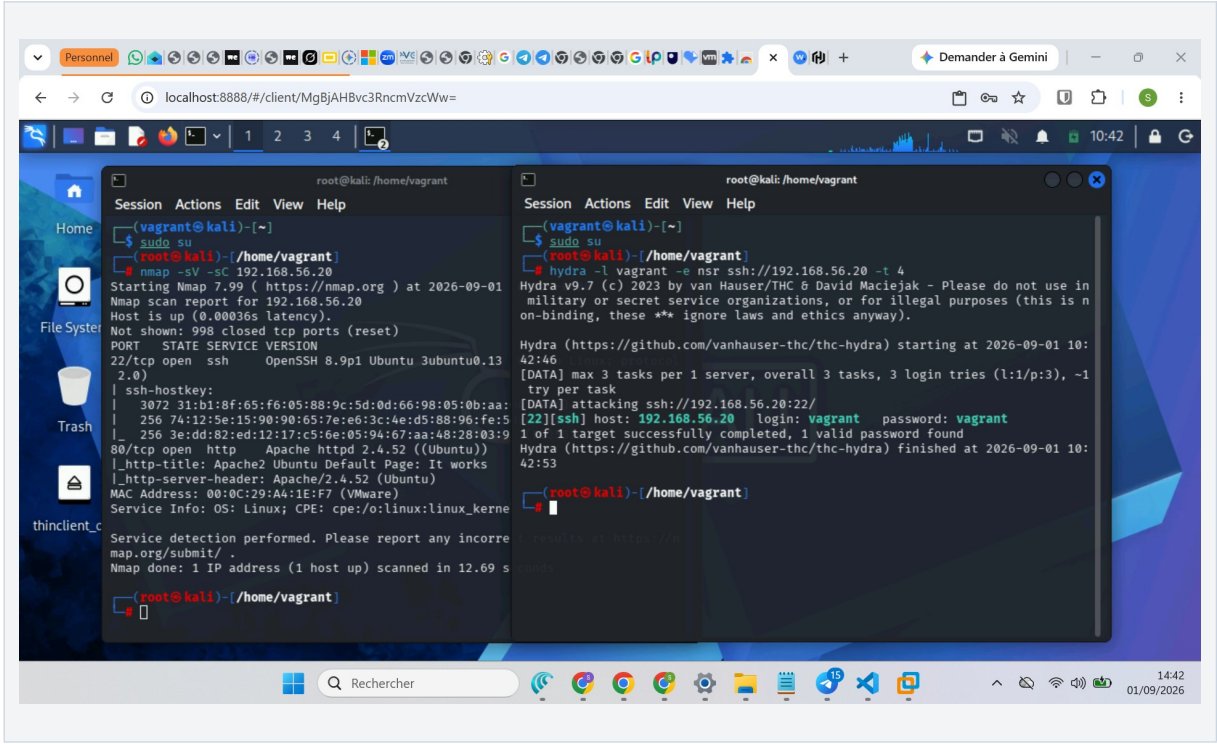


Figure 7 : Simulation d'une attaque par force brute SSH menée avec Hydra depuis Kali Linux.

5.3. Corrélation et Visualisation MITRE ATT&CK

Les événements générés par la tentative de force brute sont collectés, corrélés puis classifiés par le moteur de règles de Wazuh. Le tableau de bord dédié au référentiel MITRE ATT&CK affiche les alertes correspondant à la technique T1110 (Brute Force) ainsi qu'à la technique T1078 (Valid Accounts) en cas de succès d'authentification, permettant à l'analyste d'identifier immédiatement la nature et la gravité de l'incident en cours.

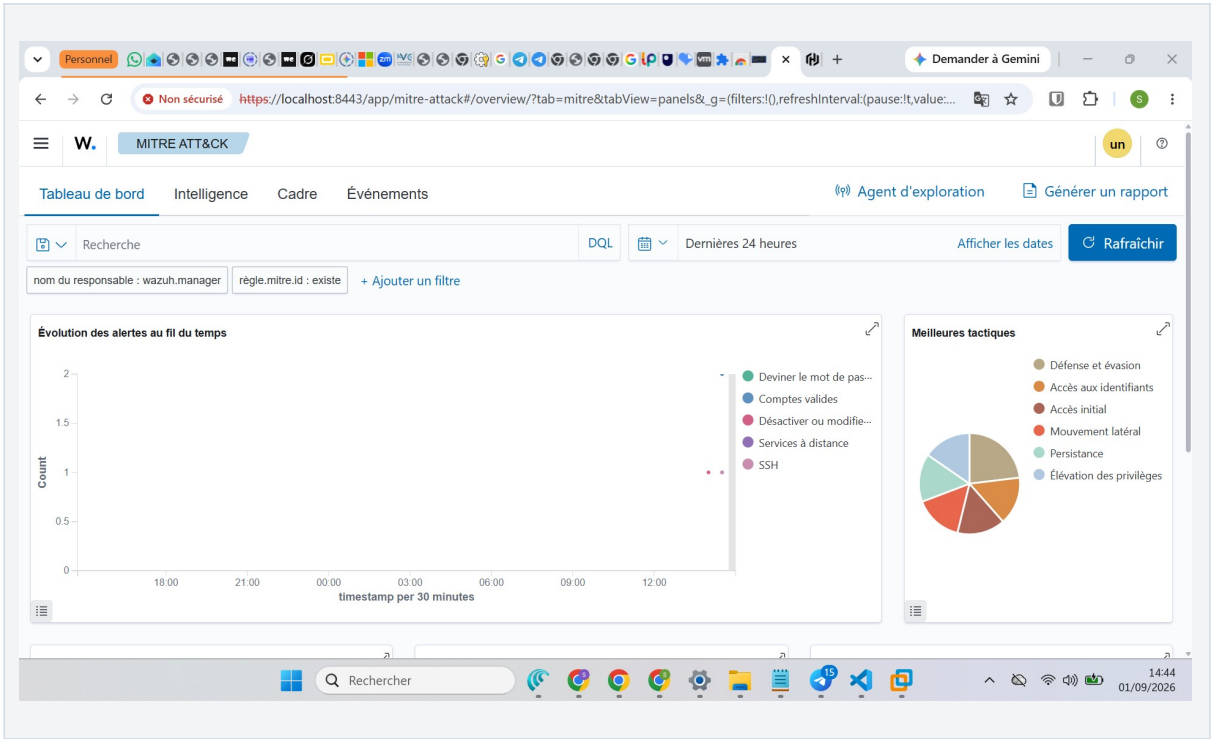


Figure 8 : Tableau de bord Wazuh présentant les alertes corrélées aux techniques MITRE ATT&CK T1110 et T1078.

6. Réponse à Incident Automatisée (Active Response)

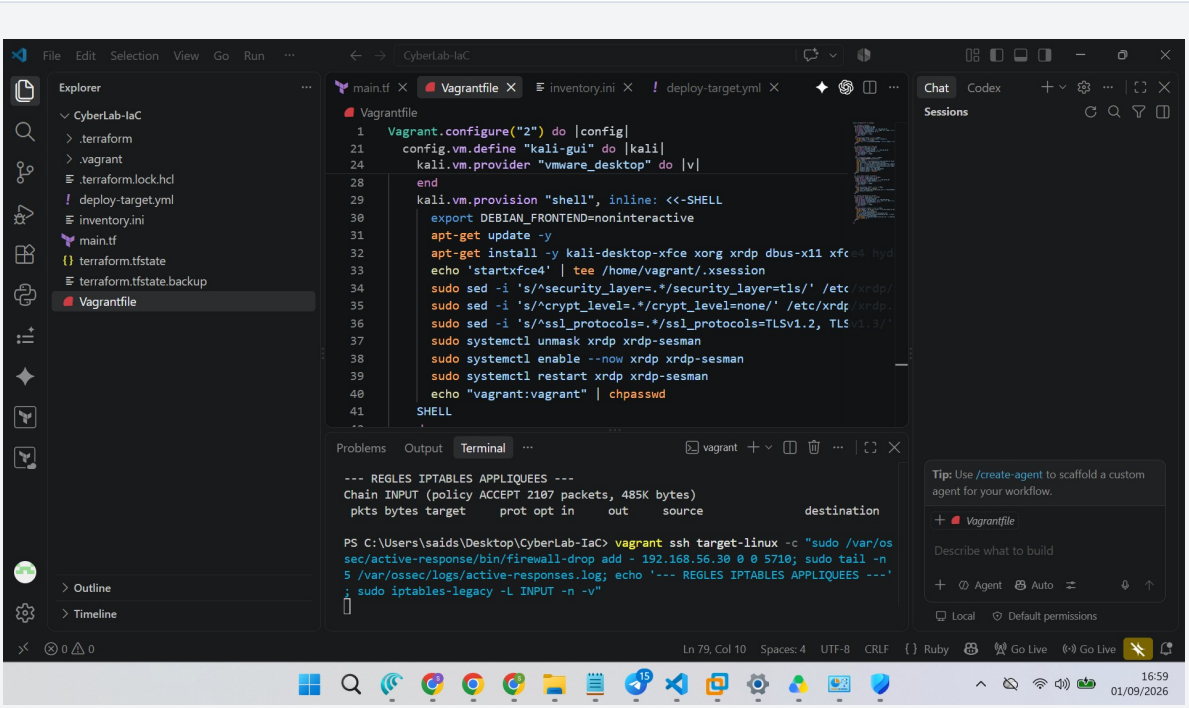
6.1. Mécanisme de Confinement Réseau

Au-delà de la simple détection, la plateforme Wazuh met en œuvre un module de réponse active (Active Response) capable de déclencher automatiquement une action de remédiation dès qu'un seuil d'alerte défini est franchi. Dans le cadre de ce projet, le module firewall-drop est asservi aux règles de détection de force brute SSH : lorsqu'un nombre configuré de tentatives d'authentification échouées est atteint depuis une même adresse IP source, le Manager Wazuh déclenche automatiquement, sur la machine ciblée, l'ajout d'une règle de blocage réseau (DROP) à l'encontre de l'adresse incriminée.

Ce mécanisme d'asservissement entre le moteur de corrélation et la couche de filtrage réseau permet de faire passer le confinement d'un incident d'une action manuelle, potentiellement tardive, à une réaction automatisée exécutée en quelques secondes — illustrant concrètement l'apport de l'automatisation sur la réduction du MTTR évoquée en introduction.

6.2. Validation du Blocage Pare-feu

La validation de l'efficacité du mécanisme de réponse active repose sur deux sources de preuve complémentaires : d'une part le journal dédié active-responses.log, qui trace l'exécution du script de blocage ainsi que l'adresse IP concernée et l'horodatage de l'action ; d'autre part l'inspection des règles IPTables effectivement appliquées sur la machine cible, confirmant la présence d'une règle DROP active et le comptage des paquets bloqués postérieurement à l'application de la règle, preuve tangible de l'interruption effective du flux malveillant.



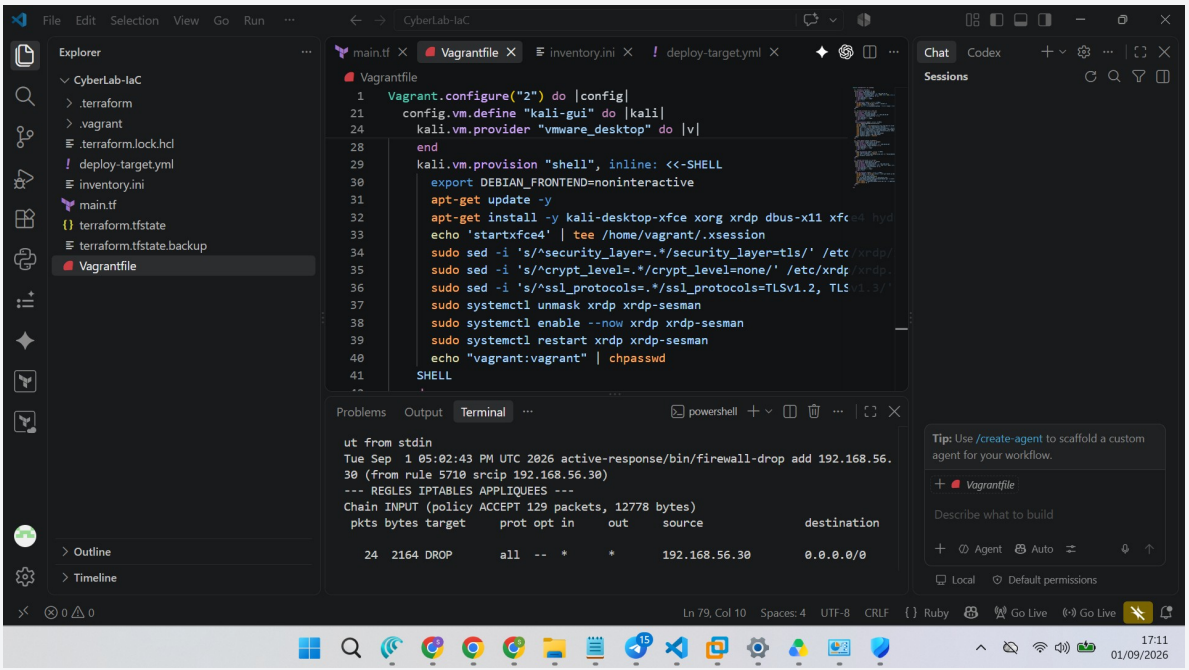


Figure 9 : Extrait du journal active-responses.log et règle IPTables DROP avec comptage des paquets bloqués.

7. Synthèse des Compétences Validées

La conduite de ce projet, de la conception de l'infrastructure jusqu'à la validation de la réponse à incident, a permis de mobiliser et de valider un ensemble de compétences transverses couvrant l'intégralité de la chaîne DevSecOps appliquée à la sécurité opérationnelle.

Domaine	Compétences techniques validées
Infrastructure as Code (IaC)	Provisioning déclaratif et reproductible d'un laboratoire multi-machines avec Vagrant, gestion de réseaux privés et automatisation du cycle de vie des VM
DevSecOps & Automatisation	Industrialisation du déploiement via Ansible (playbooks idempotents, rôles, inventaires), intégration continue de la sécurité dans la chaîne de provisioning
Administration SIEM/XDR	Déploiement et exploitation d'une stack Wazuh conteneurisée (Manager, Indexer, Dashboard), enrôlement d'agents et supervision multi-hôtes
Analyse et Détection d'Attaques	Corrélation d'événements de sécurité, cartographie MITRE ATT&CK (T1110, T1078), interprétation d'alertes SIEM en environnement réaliste
Tests d'Intrusion	Reconnaissance réseau (Nmap) et simulation d'attaques par force brute (Hydra) dans une démarche de red teaming contrôlée
Défense Active (Active Response)	Conception et validation d'un mécanisme de réponse automatisée (firewall-drop), réduction du délai de confinement et du MTTR

Ce projet démontre ainsi qu'une démarche d'automatisation rigoureuse, appliquée conjointement au provisioning d'infrastructure et à la chaîne de détection/réponse, constitue un levier direct et mesurable de réduction du temps de réponse aux incidents de sécurité, tout en garantissant la reproductibilité et l'auditabilité de l'ensemble de l'environnement.